Análisis de vulnerabilidades y amenazas

Ficha del alumnado · Seguridad y Alta Disponibilidad · 22 de septiembre de 2026

Nombre: Adrián Sayas Descalzo_ _ Grupo: _____ Fecha: _____

Hoy analizarás evidencias para localizar debilidades y distinguirás amenazas físicas y lógicas. Base: páginas 16–18 del PDF de UD1. Trabajamos con situaciones simuladas; no necesitas instalar herramientas ni acceder a sistemas reales.

Ejercicio 1 Revisamos las evidencias

35 minutos · Parejas · Una empresa de reservas os entrega estas observaciones de su sistema.

ID	Origen	Evidencia
E1	Inventario técnico	La aplicación de reservas tiene pendiente un parche que corrige un fallo conocido de acceso sin autorización.
E2	Revisión de la conexión	La página de acceso transmite las credenciales sin cifrado.
E3	Entrevista con recepción	Dos trabajadores utilizan la misma contraseña en el correo y en la aplicación de reservas.
E4	Comprobación de permisos	Una cuenta de recepción puede crear administradores aunque su tarea solo requiere gestionar reservas.
E5	Configuración del equipo	Un dispositivo conectado conserva la contraseña de administración del fabricante y un servicio remoto que nadie necesita.
E6	Visita y entrevista	El armario de equipos queda abierto y no existe un procedimiento conocido para avisar de correos sospechosos.

1. Elegid cuatro evidencias que cubran al menos tres ámbitos: software, red, credenciales, permisos, dispositivos o personas. En la página siguiente, explicad la debilidad, una amenaza que podría aprovecharla y una comprobación concreta para confirmar el problema.

2. Elegid una evidencia que pueda requerir una herramienta automatizada y otra que necesite entrevista u observación manual. Explicad qué aportaría cada método. No hace falta nombrar programas.

E1- se podría utilizar una herramienta automatizada para revisar las versiones instaladas y detectar posibles vulnerabilidades o actualizaciones pendientes.

E6- sería necesaria una observación y una entrevista. La observación permite comprobar el estado del armario y la entrevista permite saber si los trabajadores conocen el procedimiento de seguridad.

Ficha de investigación y propuesta de mejora

ID	Debilidad concreta	Amenaza posible	Cómo confirmar el hallazgo
E1	La aplicación tiene un fallo conocido y no está actualizada.	Un atacante podría acceder sin autorización.	Comprobar la versión de la aplicación y si el parche está instalado.
E2	Las credenciales se envían sin cifrado.	Alguien podría interceptar y robar las contraseñas.	Revisar si la conexión de acceso utiliza cifrado.
E4	Una cuenta de recepción tiene permisos de administrador que no necesita.	Si la cuenta es comprometida, podrían realizar cambios importantes.	Revisar los permisos de la cuenta y compararlos con sus funciones.
E6	El armario de equipos está abierto y no hay un procedimiento para correos sospechosos.	Podría producirse un acceso físico o un ataque de phishing.	Observar el armario y preguntar a los trabajadores cómo actuarían ante un correo sospechoso.

3. Para dos de los hallazgos, proponed una medida concreta y una prueba que permita comprobar si la debilidad se ha corregido.

ID	Medida	Comprobación tras corregir
E1	Instalar el parche de seguridad pendiente y mantener la aplicación actualizada.	Comprobar que la versión está actualizada y que el fallo ya no aparece.
E4	Quitar los permisos de administrador a la cuenta de recepción.	Comprobar que puede gestionar reservas, pero ya no puede crear administradores.

4. Un informe automático no muestra alertas. ¿Es suficiente para declarar seguro todo el sistema? Justificad con una evidencia del caso.

No, que un informe automático no muestre alertas no significa que todo el sistema sea seguro. Hay problemas que requieren una revisión manual. Por ejemplo, en E6 hay que comprobar físicamente el armario y preguntar al personal si conoce el procedimiento ante correos sospechosos.

5. Después se instala una aplicación nueva y cambia el personal. ¿Por qué tendría sentido repetir el análisis?

Es necesario repetir el análisis porque los cambios pueden introducir nuevas vulnerabilidades y amenazas. Una aplicación nueva puede tener fallos o una configuración incorrecta, y el nuevo personal puede no conocer los procedimientos de seguridad.

Ejercicio 2 Clasificamos sin confundir conceptos

30 minutos · Primero individual y después contraste por parejas. Clasifica cada amenaza como física o lógica, según su mecanismo directo. Indica qué afecta inicialmente y justifica la clasificación. No clasifiques solo por la consecuencia final.

Caso	Situación	Física o lógica y motivo
A	Una inundación alcanza los equipos de la oficina.	**Física:** la inundación afecta directamente a los equipos.
B	Una persona roba un portátil que contiene documentos de clientes.	**Física:** el mecanismo es el robo físico del portátil.
C	Un atacante intercepta credenciales transmitidas sin cifrado.	**Lógica:** se interceptan credenciales durante una comunicación digital.
D	Un empleado elimina por error registros mediante la aplicación.	**Lógica:** se eliminan registros mediante una aplicación.
E	Un intruso aprovecha un fallo del programa para modificar reservas.	**Lógica:** se aprovecha un fallo del programa para modificar datos.
F	Una persona corta deliberadamente el cable de alimentación del servidor.	**Física:** se corta físicamente el cable de alimentación.
G	Llega un correo que suplanta al soporte y pide introducir la contraseña en una web falsa.	**Lógica:** se utilizan medios digitales para engañar y conseguir una contraseña.
H	Un trabajador modifica deliberadamente un expediente desde su cuenta, sabiendo que no tiene permiso.	**Lógica:** se modifica un expediente digital sin autorización.

1. Clasifica estas expresiones como vulnerabilidad, amenaza o incidente ya ocurrido: «contraseña reutilizada», «posibilidad de robo del portátil», «ayer robaron el portátil».

«Contraseña reutilizada» -- Vulnerabilidad, porque es una debilidad de seguridad.

«Posibilidad de robo del portátil» -- Amenaza, porque existe el riesgo de que ocurra.

«Ayer robaron el portátil» -- Incidente, porque el robo ya ha sucedido

2. Un robo físico puede provocar una fuga de información. ¿Se convierte por eso en una amenaza lógica? Explica la diferencia entre mecanismo y consecuencia.

No, un robo físico sigue siendo una amenaza física, aunque pueda provocar una fuga de información. El mecanismo es cómo se produce el ataque y la consecuencia es el daño que provoca. En este caso, el mecanismo es robar el portátil y una posible consecuencia es acceder a los documentos de clientes.

3. Dos estudiantes afirman: «toda amenaza humana es lógica» y «toda amenaza interna es accidental». Refuta cada frase usando un caso de la tabla.

«Toda amenaza humana es lógica» -- Falso, el caso F demuestra que una persona puede provocar una amenaza física al cortar el cable de alimentación de un servidor.

«Toda amenaza interna es accidental» -- Falso, el caso H demuestra que una amenaza interna también puede ser intencionada, ya que el trabajador modifica deliberadamente un expediente sin tener permiso.

Entrega: ficha de investigación, dos medidas con sus comprobaciones, clasificación de los ocho casos y respuestas razonadas. Se valorará la relación entre evidencia y conclusión.